Email Header Injection Vulnerability Report

Expert track, redacted for publication. Vulnerability analysis, exploitation methodology and remediation.

1. Executive Summary

This vulnerability exists in an internal email forwarding service that processes incoming messages. The service fails to sanitize email headers, allowing attackers to inject arbitrary headers and redirect mail flow.

2. Vulnerability Description

The service directly inserts user-controlled input into email headers without sanitizing newline characters or header delimiters. This allows attackers to add arbitrary headers, modify recipients, and redirect emails.

3. Exploitation Methodology

1. Identify that the email service processes user-controlled fields in message headers.
2. Inject newline characters followed by arbitrary email headers into user input fields.
3. The service accepts the injected headers and processes the modified mail flow as intended.

4. Impact

This allows attackers to redirect internal emails, spoof sender identities, and bypass email-based access controls.

5. Remediation Recommendations

Sanitize all user-controlled input that goes into email headers, blocking newline characters and header delimiters. Use a dedicated email library that handles header encoding safely, rather than constructing headers manually.